

Cybersecurity (F26)

18th March 2026

Sani Abdullahi, Ph.D.

[\[saa@mmmi.sdu.dk\]](mailto:saa@mmmi.sdu.dk)

With thanks to Oksana Kulyk

Course Plan

Lecture	Date	Teacher	Topic
01	2026-02-04	Sani	Introduction & Lab Set-up
02	2026-02-11	Sani	Vulnerability Assessment
03	2026-02-18	Sani	Penetration Testing
04	2026-02-25	Hiraku	Firewalls and IDS
05	2026-03-04	Hiraku	Malware & SQL
06	2026-03-11	Hiraku	Denial of Service
07	2026-03-18	Sani	Social Engineering, Phishing
08	2026-03-25	Sani	Threat Modelling I
09	2026-04-08	Hiraku	Cryptography
10	2026-04-15	Hiraku	Multi-party Computation
11	2026-04-22	Hiraku	Privacy-preserving Data Analysis
12	2026-04-29	Sani	Threat Modelling II, Revision, & Exam Prep.

Information

→ Exercise Submission

- Deadline for submitting all 6 exercises: **May 29th**
- Extended deadline for group registration: **March 31st**
- Reuse ONE group to submit all exercises
- You cannot see the assessment results until the final submission/deadline

→ DDoS & MITM class replaced with Thread Modeling I

→ Mid-term Evaluation: <https://pollev.com/sani>

- Active until **April 6th**

Cybersecurity Incident of the Week

'Social advertising is being used to defraud at scale across some of the largest platforms.': Nearly one in three Meta ads reportedly point to a scam, phishing or malware

News By Sead Fadi pašić published February 24, 2026

Scam ads create millions of impressions every month



Ransomware Losses Climb as AI Pushes Phishing to New Heights

Based on real-world insurance claims, Resilience's midyear report shows vendor risk is declining but costly, ransomware is evolving with triple extortion, and social engineering attacks are accelerating through AI.

 By Kevin Townsend | September 9, 2025 (9:28 AM ET)
SDU 



Cybercrime group claims credit for voice phishing attacks

Security researchers at Okta previously disclosed a social engineering campaign involving custom phishing kits.

Published Jan. 26, 2026 • Updated Jan. 27, 2026



FBI raises alarm over Scattered Spider targeting airline sector with social engineering schemes

JULY 02, 2025

This week: The University of Pennsylvania breach exposes data of 1.2 million people, a massive phishing campaign impersonates Booking.com to target hotels and Google warns users about six major scams sweeping the web. **November 12, 2025**

Social Engineering

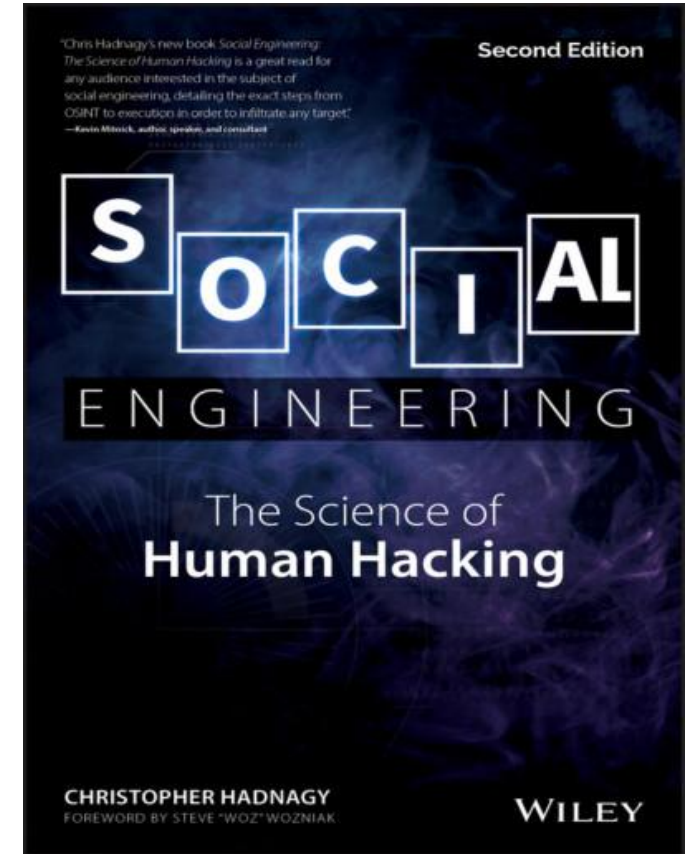
Learning Objectives

By the end of this lecture, you should be able to:

- Understand various social engineering attack methods, including both digital and physical approaches.
- Explain the stages and lifecycle of a social engineering attack from reconnaissance to execution.
- Understand and analyze different pretexting and persuasion techniques, including the psychological principles attackers use.
- Describe how phishing attacks work, including common tools and methods used to carry them out.
- Identify and apply techniques for detecting and preventing phishing and other social engineering attacks.

Social Engineering

- **Definition:** Any act that influences a person to take an action that may or may not be in their best interest.
- **Also:** A psychological manipulation technique used to persuade individuals into making decisions or disclosing information they might not otherwise share.
- Social engineering is commonly associated with cybersecurity threats such as phishing, pretext, and impersonation.
- Often cybersecurity-related, but social engineering tactics can be used in “traditional” scams.
- Often associated with malicious intent, but it can also be used for positive and ethical purposes, e.g., behavioral change towards a positive individual / societal effect.



Social Engineering

Methods of Attack

- Phishing e-mails
- Spear-phishing emails
- Credential harvesting
- Whaling (CEO fraud)
- Smishing
- Evil USB
- Attached files, e.g., PDF, Excel or e-mail
- Visit on site

Can be categorized into digital and physical



Social Engineering

Digital methods

- **Phishing** – A deceptive tactic where attackers impersonate a trusted entity to trick users into revealing sensitive information.
 - **Vishing (Voice Phishing)**
 - **Smishing (SMS Phishing)**
- **Baiting** – A technique where attackers lure victims into compromising security by offering something tempting.
- **Waterholing (watering the hole)** – A strategy where attackers compromise a legitimate website frequently visited by a target group.
- **WiFi Spoofing** – Attackers set up fake WiFi hotspots with names that mimic legitimate networks

Warning Issued to Troops Receiving Strange Smartwatches in the Mail



Airman wears a smartwatch, Dec. 3, 2020, at Hill Air Force Base, Utah. (U.S. Air Force photo by Cynthia Griggs)

Social Engineering

Physical methods

- **Dumpster Diving:** Attackers search through trash bins or discarded documents to find sensitive information. Even shredded documents can sometimes be reconstructed.
- **Tailgating (Piggybacking):** Attacker gains unauthorized access to a restricted area by following an authorized person, often by pretending to have forgotten their access card or carrying items to appear as an employee.

TRANSPORTATION

A British man boarded a flight to NYC without a passport or a boarding pass by tailgating behind unsuspecting passengers, report says

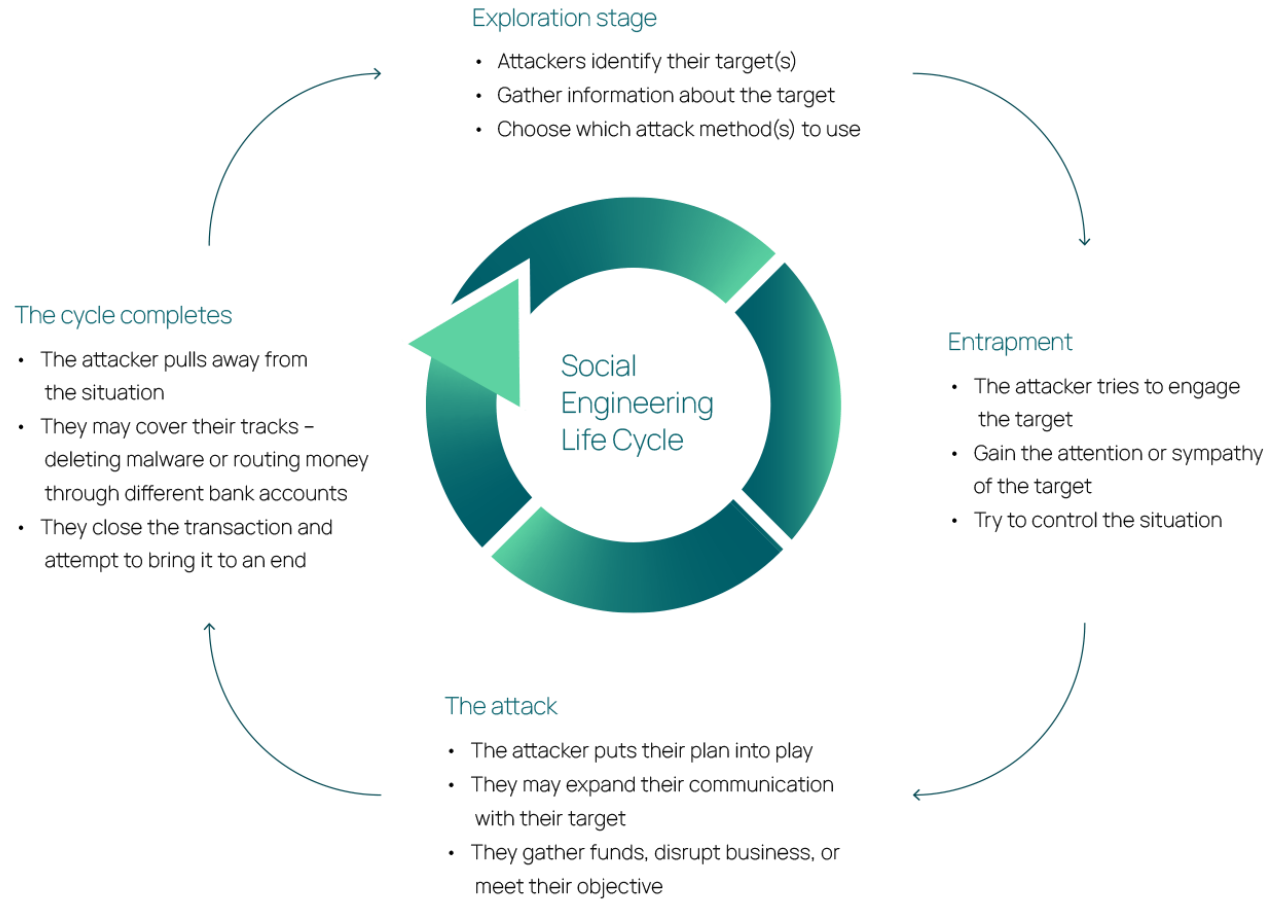
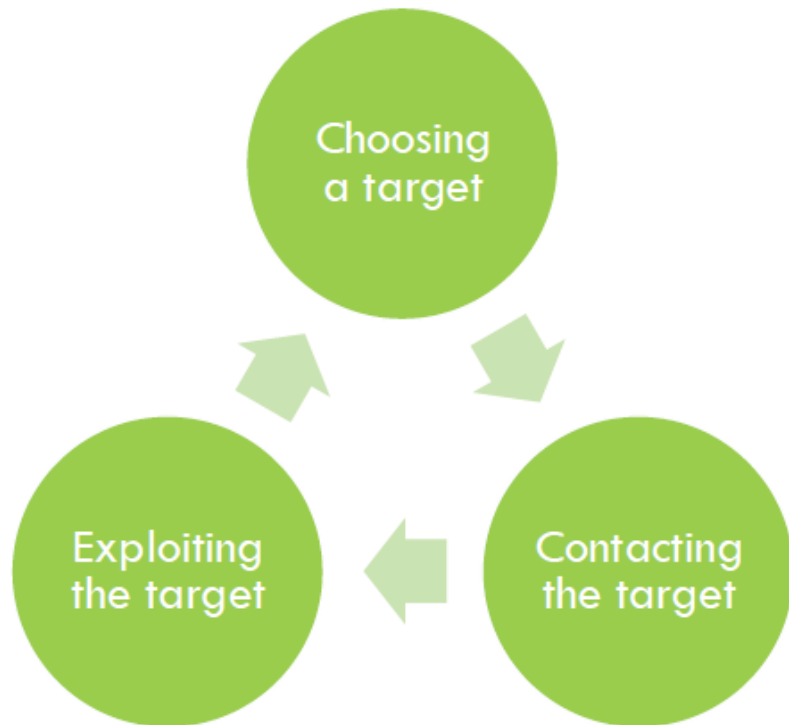
Joshua Zitser Feb 12, 2024, 12:37 PM CET

Share | Save

- **Shoulder Surfing:** A method where attackers physically observe someone entering sensitive information, such as:
 - Watching a person type their password or PIN at an ATM or login screen.
 - Overhearing confidential conversations in public places like cafés or public transport.
 - Observing sensitive documents left open on desks or screens.

Social Engineering

Steps & Life-Cycle



Life-Cycle of a Social Engineering Attack

Social Engineering

Choosing a target

- **Goal:** identify which people have access to the data or system components they are interested in. This process often involves information gathering
- Can also be a pivoting point, i.e. using the initial target as a steppingstone for further attacks (e.g., an employee's account is compromised that is used for internal emails)
- Target specificity:
 - **Explicit target:** attacker focuses on specific individuals who have valuable access, e.g., CEO
 - **Opportunistic target:** attacker targets a large group to increase their chances of success, e.g., phishing emails.
 - **Hybrid approach:** attacker combines both explicit and opportunistic targeting, e.g., setting up a malicious WiFi network.

Social Engineering

Contacting the target

- **Method of contact depending on attacker's goal:**
 - Extract sensitive information (e.g., passwords, financial data).
 - Deploy malware on a victim's device.
 - Gain physical or remote access to a system or network.
- Can be one-off contact or long-term relationship/observation
- Can be manual or automated
- A variety of tactics to make contact more successful:
 - **Personalization** via information gathering
 - **Pretexts** and **persuasion** tactics

```
Select from the menu:

1) Spear-Phishing Attack Vectors
2) Website Attack Vectors
3) Infectious Media Generator
4) Create a Payload and Listener
5) Mass Mailer Attack
6) Arduino-Based Attack Vector
7) Wireless Access Point Attack Vector
8) QRCode Generator Attack Vector
9) Powershell Attack Vectors
10) Third Party Modules

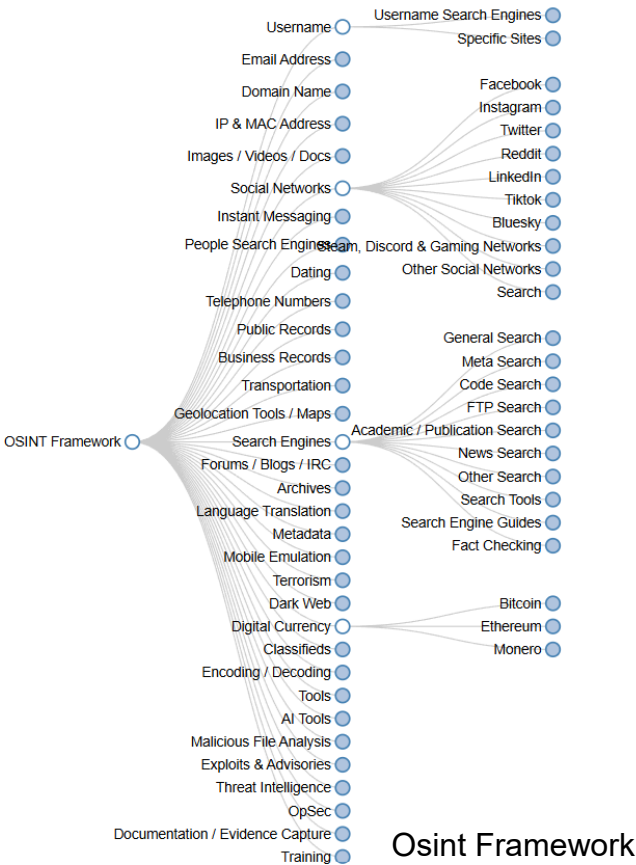
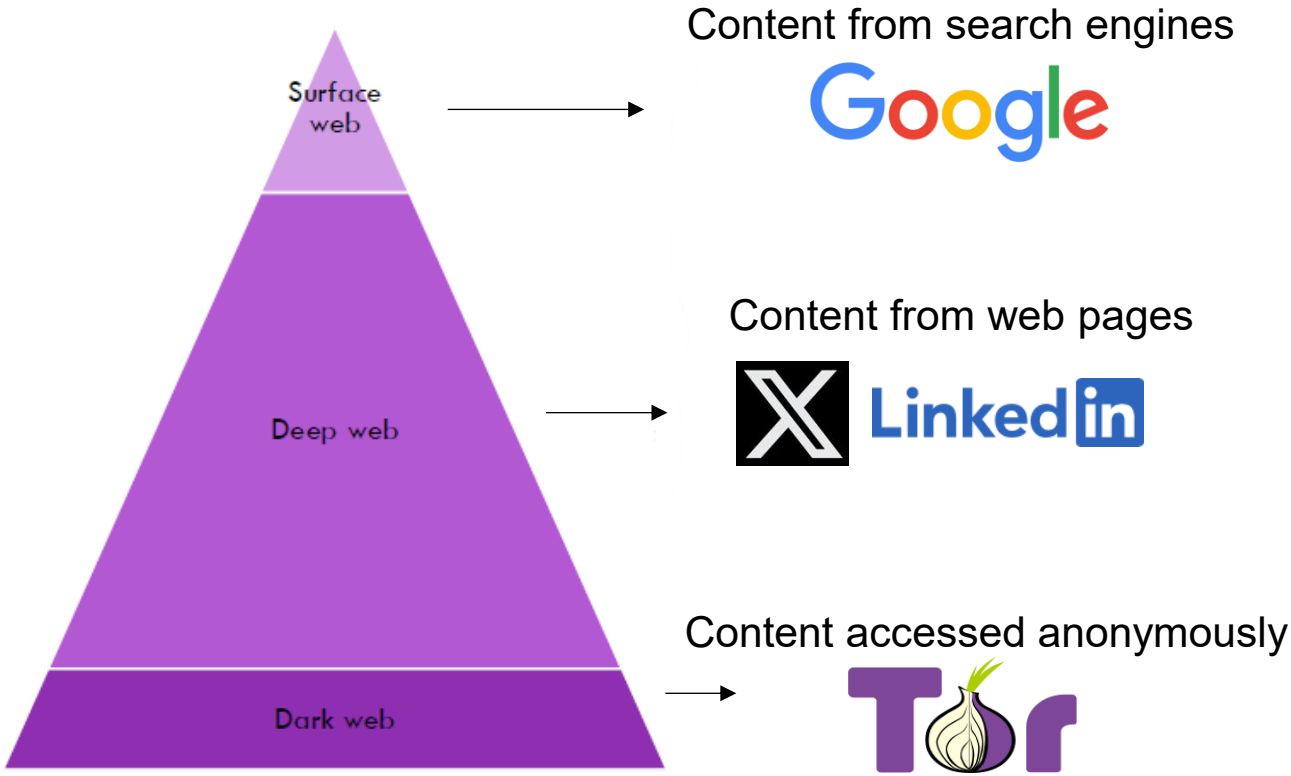
99) Return back to the main menu.

set> █
```

Social Engineering Toolkit

Social Engineering

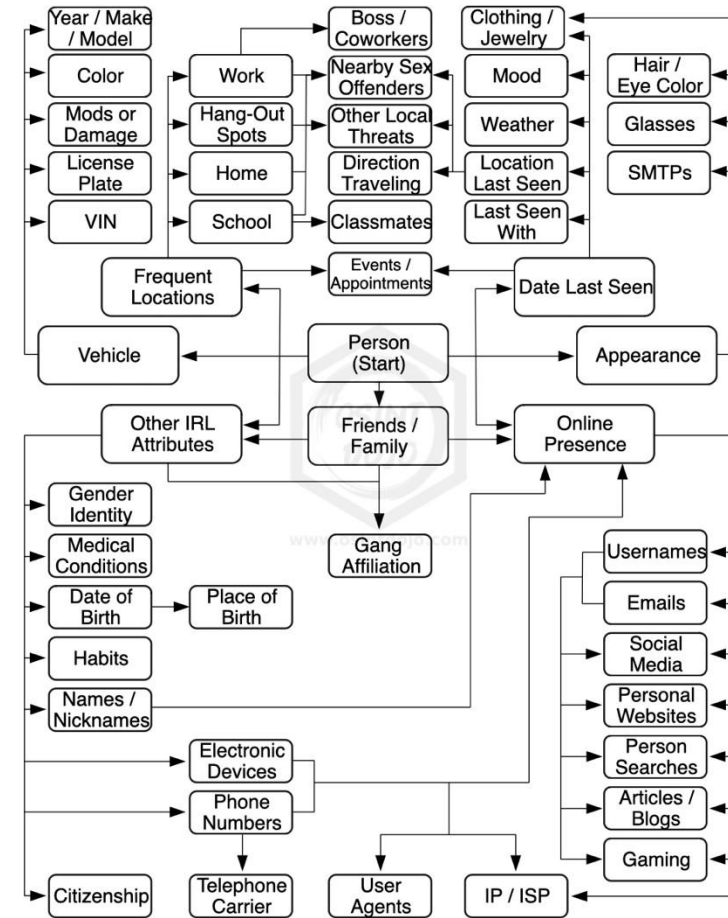
Information gathering



Social Engineering

Information gathering: Personal

- Governmental records (services krak.dk)
- Social media, incl. forums, message boards...
 - Basic information: name, employment, relationship status
 - Usernames: can be used to identify other online accounts
 - Interactions with people/services: likes, check-ins, friends...
- Content posted by others
 - Friends/family on social media
 - Company website
 - Media reports
 - ...



<https://www.osintdojo.com/diagrams/person>

Social Engineering

Information gathering: Organizations & Data breaches

- Public records, e.g. CVR register, court documents, etc.
- DNS records (see e.g. whois.com)
- Information directly from the company: website, press releases, social media, etc.
- Information from company employees (e.g. social media)
- Information about user accounts (e.g., passwords/login credentials)

Domain:	gamess.dk
DNS:	gamess.dk
Registered:	2023-05-08
Expires:	2025-05-07
Registrar:	ONE.COM A/S
Registration period:	1 year
VID:	no
DNSSEC:	Signed delegation
Status:	Active

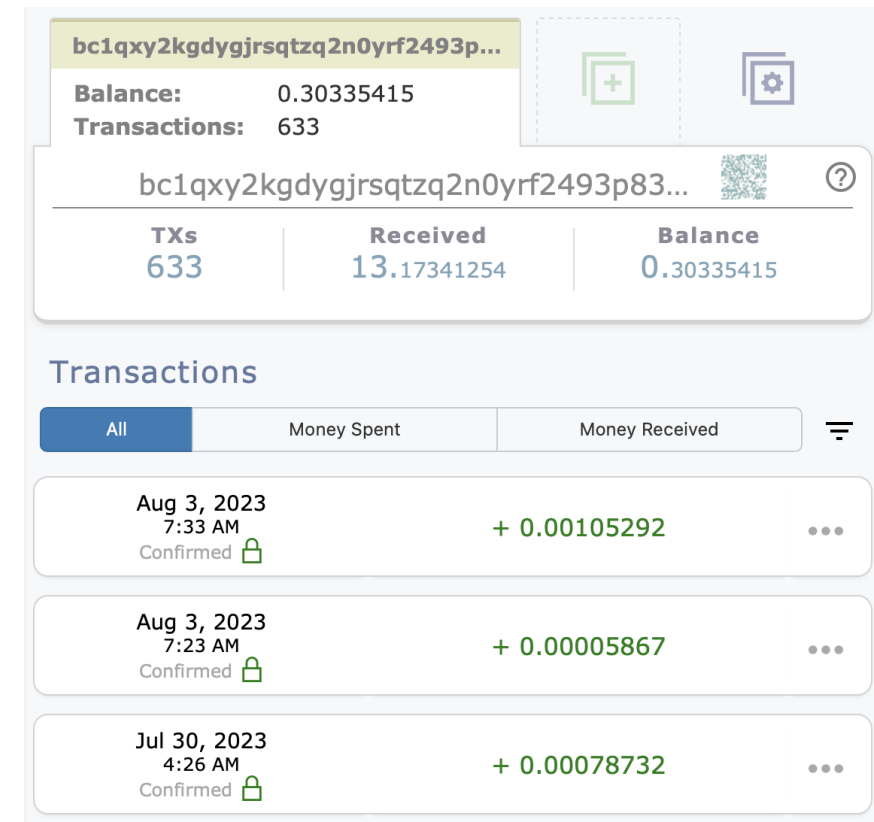
Oh no — pwned!

Pwned in 7 [data breaches](#) and found no [pastes](#) ([subscribe](#) to search sensitive breaches)

Social Engineering

Information gathering: Financial

- Public information, e.g. tax records
- Leaks, e.g. financial papers, payment service transactions, etc.
- Cryptocurrency
 - Transactions history of a certain public key + network analysis
 - Spending and income patterns
 - Exchange activity and wallet connections
 - Identities connected to certain accounts, personal/business pages, location, etc.



The screenshot displays a cryptocurrency wallet interface. At the top, a yellow header bar shows a truncated public key: `bc1qxy2kgdygjrqtzq2n0yrf2493p...`. Below this, the current **Balance** is 0.30335415 and there are 633 **Transactions**. To the right are icons for adding (+) and settings (gear). Below the header is a section with a QR code and a question mark icon, showing a truncated address: `bc1qxy2kgdygjrqtzq2n0yrf2493p83...`. A summary table follows:

TXs	Received	Balance
633	13.17341254	0.30335415

Below the summary is a **Transactions** section with tabs for **All**, **Money Spent**, and **Money Received**. A list of three transactions is shown, all marked as 'Confirmed' with a lock icon:

Date	Time	Amount
Aug 3, 2023	7:33 AM	+ 0.00105292
Aug 3, 2023	7:23 AM	+ 0.00005867
Jul 30, 2023	4:26 AM	+ 0.00078732

Social Engineering

Pretext: Examples

Work

From: Alice <alice-mail@gmail.com>
To: Bob <bob@supertech.com>
Subject: Technnovation presentation

Hi Bob,

As you know, our research team will present our latest product at the Technnovation conference next month. As we need contributions from all our team members, we have set up a portal with the most current information about the event [here](#) (you would need your company login to access it). Please check that the information about your part of the project is accurate.

Best regards,
Alice

- Use current event to make conversations convincing

Personal

From: Jane
To: Bob

Hi Bob,

This is Jane Smith, we used to sit next to each other in the Advanced Programming class at the IT University. I saw the photos you posted and decided to reach out ;) How have you been doing?

From: FitnessPlus <info-fitnessplus@gmail.com>
To: Bob <bob@bob.com>
Subject: New offers for your gym membership

Dear Bob,

We have now opened new gym locations and have prepared some exciting new offers, including new classes and personal training sessions, to our members. Please check the attached file for a full overview of our offers.

Best regards,
FitnessPlus team

📎 [Activities.pdf](#)

- Establishing further rapport with the target

Work + Personal

From: Alice <alice-mail@gmail.com>
To: Bob <bob@bob.com>
Subject: Access to budget

Hi Bob,

Can you please share with me the document with the budget overview? I am currently traveling, so I don't have access to my work device – but I need to finish my report by the end of the week, and I need the numbers from the budget for it...

Thanks a lot!
Alice

- Use work and personal information to make the approach more believable

Social Engineering

Persuasion tactics: Examples

- Offering or promising a reward
 - Response to being offered rewards
- Liking and social proof
 - Do favors for someone they like or members of own social group
- Trustworthiness
 - Based on appearance (people, companies, websites, etc)
- Appeal to authority
 - Likely to follow authority and urgency

[HOME](#) > [MILITARY & DEFENSE](#)

Ukrainian hackers created fake profiles of attractive women to trick Russian soldiers into sharing their location, report says. Days later, the base was blown up.

Sophia Ankel Sep 5, 2022, 4:27 PM

Sony hackers used fake Apple ID emails to steal passwords, says researcher

 BY COLLEN KRIEL

According to McClure, the fake emails were near identical to official AppleCare emails instructing users to verify their Apple IDs. Users had to take action within 48 hours, stated the emails, or face being locked out of their Apple accounts.

Technology

Austria's FACC, hit by cyber fraud, fires CEO

The firm's supervisory board decided at a 14-hour meeting on Tuesday to dismiss CEO Walter Stephan with "immediate effect", the company said on Wednesday.

FACC, whose customers include Airbus and Boeing, said on Jan. 19 it had been hit by a cyber fraud in which hackers stole around 50 million euros by posing as Stephan in an email.

The hoax email asked an employee to transfer money to an account for a fake acquisition project - a kind of scam known as a "fake president incident".

Social Engineering

Persuasion tactics: Psychological Techniques

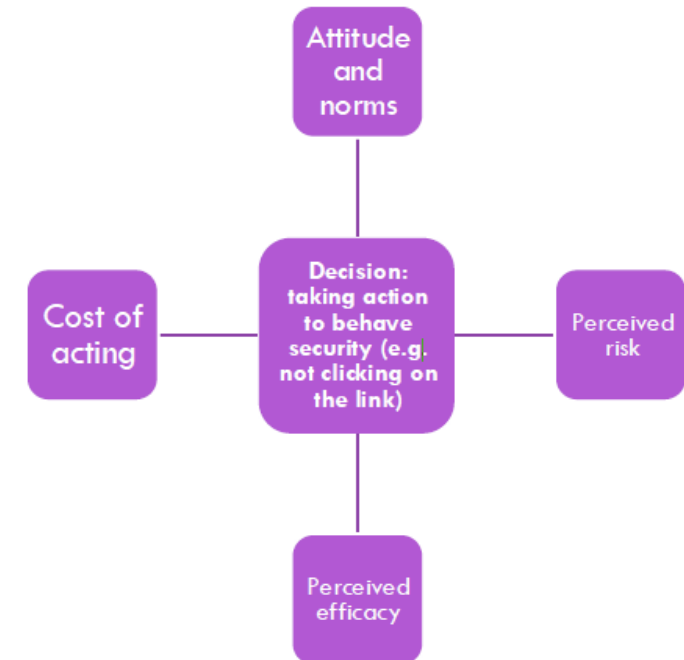
- **Authority:** Pretending to be someone important.
- **Fear and Urgency:** Creates panic to act quickly.
- **Scarcity and Urgency:** Limited time offer or few spots
- **Trust and Familiarity:** Pretend someone you know or trusted.
- **Plausibility:** Belivable enough not to question it
- **Curiosity, Reciprocity, Convenience,** etc.



Decision Making

Factors influencing decision

- **Context-Dependent Decisions:** People make security decisions based on the situation.
- **Emotional Triggers:** Decisions made based on emotions.
- **Non-Automatic Decisions:** Security actions are often not automatic. Often require active thought and decision-making.
- **Cognitive Bias:** Security-related tasks perceived as obstacles.
- **Barriers to Compliance:** Security tasks such as verifying emails or checking physical security are often viewed as annoyances.



Social Engineering

Penetration testing

- **Idea:** To let someone (e.g., external team of experts) try to attack the organization using SE methods.
 - Similar principle to “classical” penetration testing
- **Issues to consider:**
 - How much information can one get about a person/company? Are illegal/“gray area” sources (e.g. content of leaked data breaches) ok to use? Is active social engineering (e.g., directly getting in contact with the target or their social circles) ok?
 - Which pretexts and persuasion tactics are ethical to use?
 - How are the results reported; should specific people be named? Should information about them found via information gathering be shared with their employees?
- Also, phishing campaigns are considered as penetration testing in the context of SE.

Social Engineering

SE Scenario

- John is a security guard tasked with protecting the physical premises of the company from unauthorized access. A visibly pregnant woman approaches him: she is not feeling well, and her phone is not working, so she needs to be let inside the building to use one of their phones for calling for help and to use a bathroom.
- **What should John do?**
 - Ignore the request - The woman might have serious health issues
 - Let her in - The woman might use the access to the building to e.g. plant eavesdropping devices or removable media with malware
- Can be addressed by e.g., having a second security guard who stays at the entrance while John helps out the woman while making sure, she does not do anything suspicious.

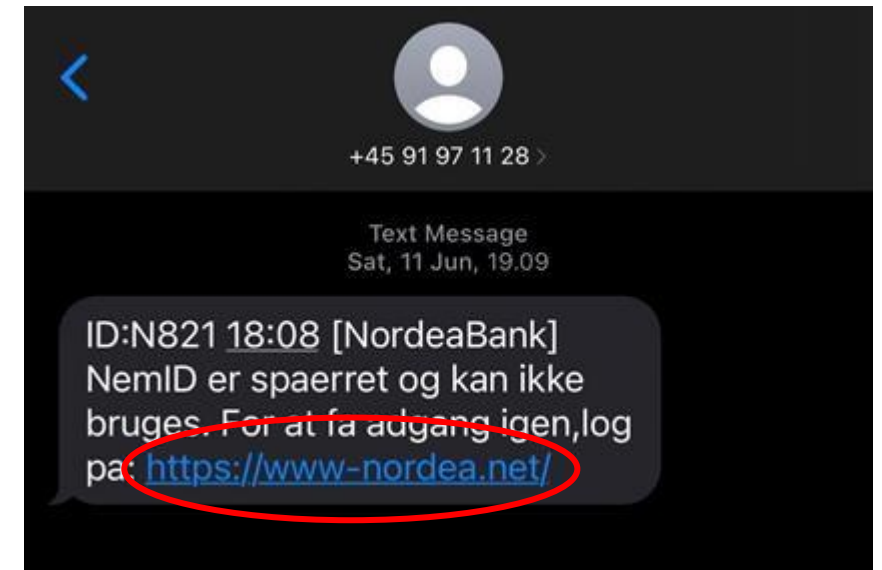
Phishing

Phishing

- A variant of social engineering attack
- Attacker sends emails (or messages via other channels, e.g. SMS) impersonating a trusted entity

How can one tell this is not a real message from Nordea?

- **Main indicator:** link does not lead to Nordea website
- **Other possible indicators:**
 - Time of message: Saturday evening
 - Spelling mistakes
 - Content invoking sense of urgency



Phishing

How phishing works: Credential stealing

1. User get an email with a link to a website of a trusted organization.
2. The link goes to the website that looks like the one from the real organization but is owned by the attacker.
3. User is prompted to enter credentials
4. Credentials forwarded to the attacker
5. Attacker gets full control over user's account

Phishing

How phishing works: Malware infiltration

1. User gets an email with an attached file
2. User opens the attachment in the email
3. Attachment runs malware script
4. Malware gets control over the users' system (e.g. sending data to the attacker) and/or propagates to other users/devices on the network.
5. In rare cases: malware can run even without the user opening the file: clicking the link, or even just reading the email, especially dangerous for systems without security updates

Phishing

How phishing works: CEO fraud

1. User gets an email impersonating a trusted person/authority
2. The email contains instructions: transferring money, sharing sensitive documents, etc.
3. User follows the instructions

Phishing

How phishing works: Regular phishing

- Attacker's investment:
 - Register email addresses to use for phishing mailing
 - Register a website to make it look like the one the attacker wants to impersonate, or:
 - Prepare malware to be attached
 - Send out phishing emails
- Openly available tools incl. generative AI exist to help

```
Select from the menu:

1) Spear-Phishing Attack Vectors
2) Website Attack Vectors
3) Infectious Media Generator
4) Create a Payload and Listener
5) Mass Mailer Attack
6) Arduino-Based Attack Vector
7) Wireless Access Point Attack Vector
8) QRCode Generator Attack Vector
9) Powershell Attack Vectors
10) Third Party Modules

99) Return back to the main menu.

set> 
```

Social Engineering Toolkit

After WormGPT, FraudGPT Emerges to Help Scammers Steal Your Data

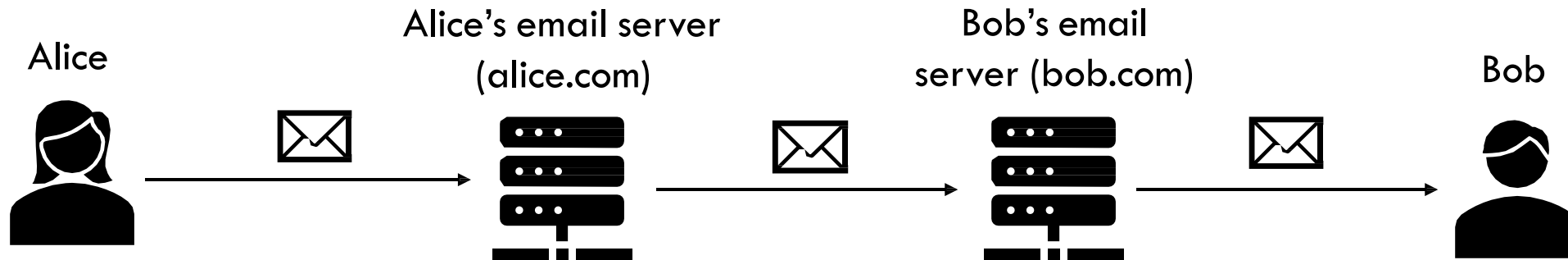
The arrival of WormGPT and now FraudGPT signals that hackers are seizing the opportunity to create AI-powered chatbots to facilitate cybercrime and scams.

by Michael Kan
Jul 25, 2023

f X in p

Phishing

How email works

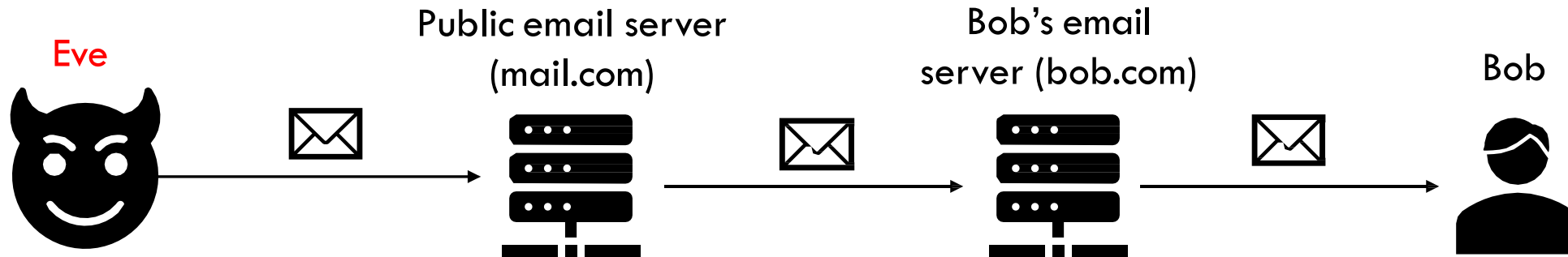


From: Alice <alice@alice.com>
To: Bob <bob@bob.com>
Subject: Meeting agenda

Simple **M**ail **T**ransfer **P**rotocol: originally designed in 1980, no initial security considerations in mind

Phishing

Sender spoofing: Sender's name



From: **Alice** <eve@mail.com>
To: Bob <bob@bob.com>
Subject: Meeting agenda

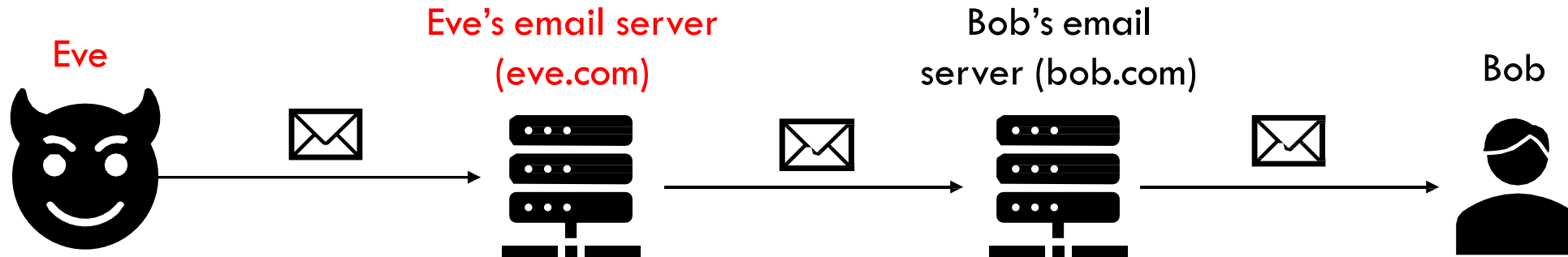
Sender's name falsifiable

Sender's address can look similar enough to be believable

- “alice@mail.com” (if account was not registered herself) or “alice@eve.com”

Phishing

Sender spoofing: Sender's address



From: Alice <alice@alice.com>
To: Bob <bob@bob.com>
Subject: Meeting agenda

Senders' email falsifiable if:

- Attacker controls the server
- or the email provider's server is incorrectly configured

Phishing

Website spoofing

From: YourBank <yourbank-service@mail.com>

To: Bob <bob@bob.com>

Subject: Bank account compromised

Dear Bob,

Unfortunately, your bank account has been compromised and has therefore been blocked. Please go to our website following this link: <https://yourbank.com/account-restore> and enter your online banking login and password to restore the account.

<https://evilhacker.org/phishing>

- Real link destination can be hidden in email text, visible only via tooltip/hovering on the link
- Further tricks to disguise the actual URL 

Phishing

Trick 0: No Trick

evilhacker.org

182.15.128.103

- Should be easy to detect
- Still, the user has to pay attention to the URL

Trick 1: URL Shortners

<https://tinyurl.com/bffte48x>

- Hard to distinguish without clicking on the link
- Services to check shortened URLs exist. Need to be explicitly checked

Unshorten.It!

<https://tinyurl.com/bffte48x>

Unshorten.It!

Not got a short URL to try? Here's one: <http://bit.ly/GVBQJS>

This website does not have a title

Destination URL:

<http://evilhacker.org>

Phishing

Trick 2: Legitimate website as part of URL

amazon.com → amazon.com.evilhacker.com

facebook.com → evilhacker.com/www.facebook.com

- A problem if user doesn't know how to identify the website domain
- A problem if only a part of URL is shown (e.g. on mobile devices)

Trick 3: Similar domains

amazon.com → amazon-shop.com

- A problem if the user does not know what the real website is

Phishing

Trick 4: (Almost) Indistinguishable domains

amazon.com → arnazon.com

microsoft.com → mircosoft.com

facebook.com → fácebook.com

apple.com → apple.com

- Especially hard to notice!

Trick 5: Compromised legitimate websites

amazon.com → evilhacker.amazon.com

amazon.com → amazon.com/evilhacker

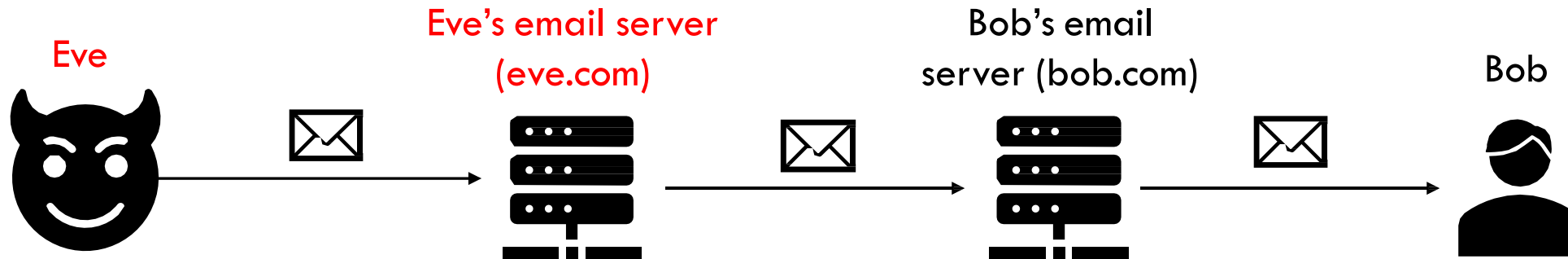
amazon.com → amazon.com/login?redirect=https://evilhacker.org

- Impossible to notice based on URL alone – website owners must take measures

Phishing detection

Phishing

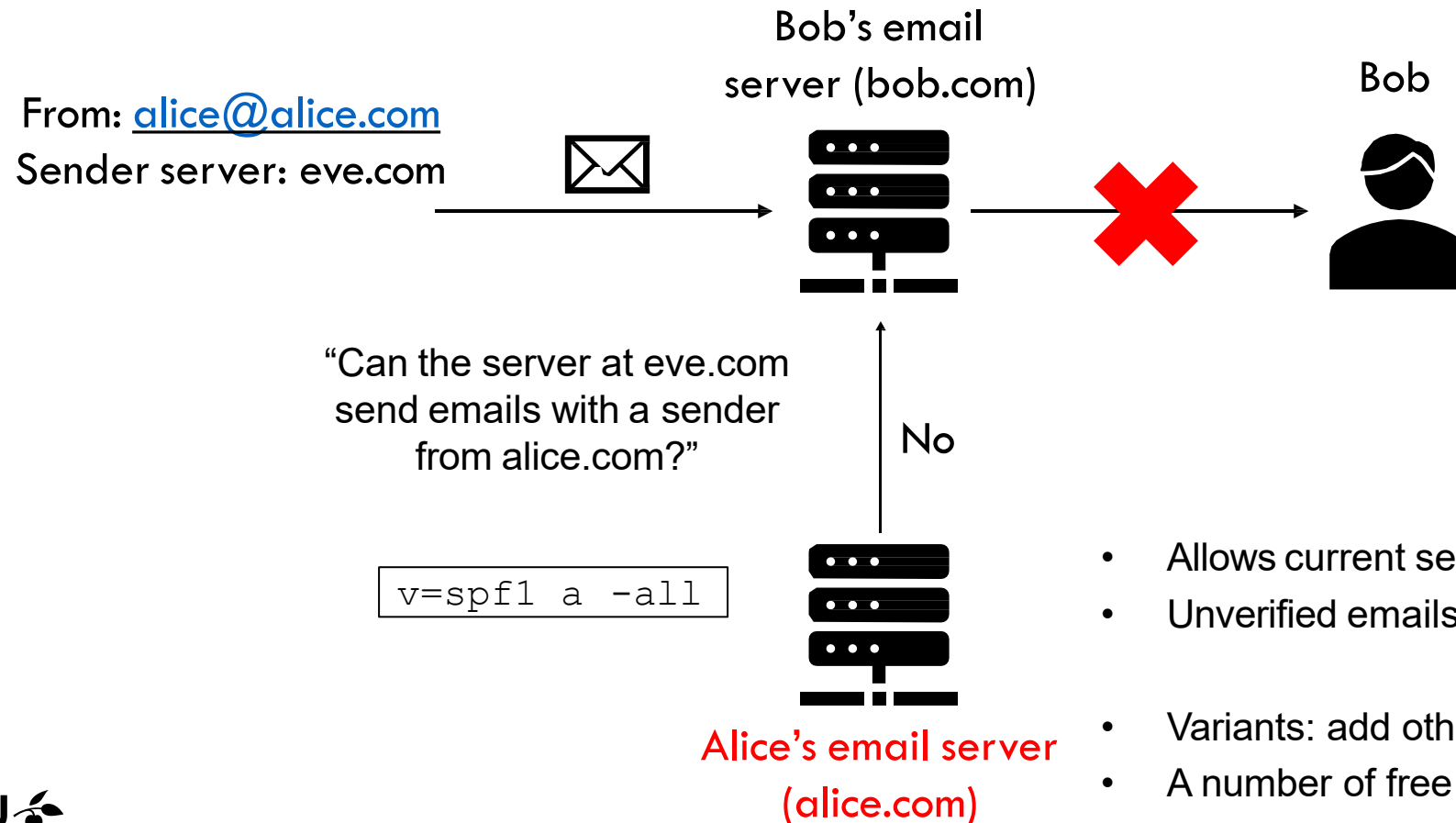
Domain verification: Sender spoofing



- **Scenario:** Eve wants to impersonate Alice
- She uses her own email server (eve.com) to spoof the sender as alice@alice.com
- **Solution:** Sender Policy Framework (SPF) record
- **Idea:** Check with Alice's email server (alice.com) whether the server sending the email (eve.com) on Alice's behalf is actually allowed to do so
- If not:
 - either soft fail (email delivered to Bob but marked as failed verification)
 - or fail (email not delivered)

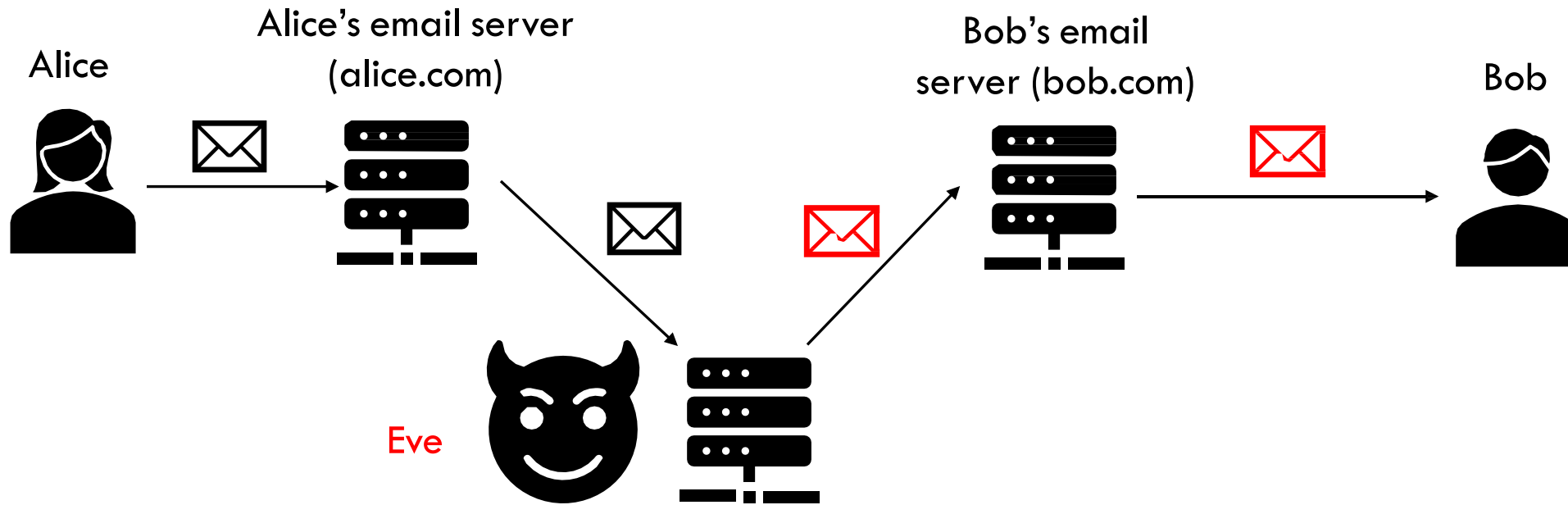
Phishing

Domain verification: Sender policy framework



Phishing

Domain verification: Message spoofing



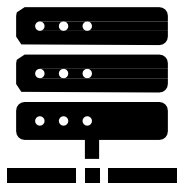
- **Scenario:** Eve wants to impersonate Alice
- She intercepts the message sent by Alice and changes its content before it gets delivered to Bob
- **Solution:** digital signatures via DomainKeysIdentified Mail (DKIM)

Phishing

Domain verification: DomainKeyIdentified Mail

How it Works

alice.com

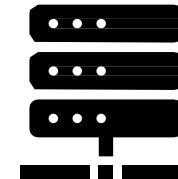


Bob



- The *secret* key of alice.com needed to sign
- The *public key* of alice.com needed to verify the signature
- Signature ensures that email is sent via alice.com and has not been tampered with in transit.

Bob's email
server (bob.com)



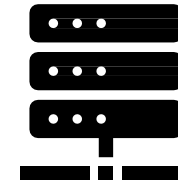
Bob



“Has this message been
signed with the public key
of alice.com?”

No

```
v=DKIM1;t=s;p=MIGfMA0G
CSqGSIB3DQEBAQUAA4GNAD
CBiQKBgQDTQSnWt4zsHrr2
ybQ1gq2L3Kbb035ZaPMKWH
IRJ1NAyLIHctY8o/u05xMz
YkX7opLTbpjJKI77C6z/pu
g8Z/NQntvx1Jam6++6WLu
zHgROBus+bJ23NFFhAnsEi
```

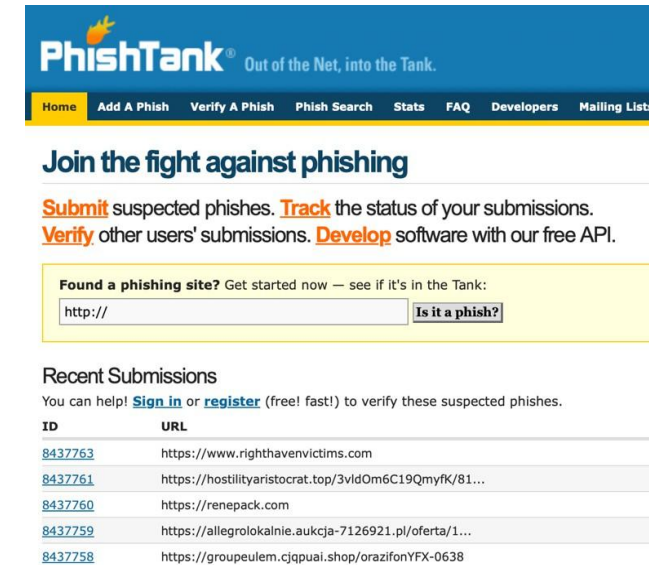


DNS records

Phishing

Blocking of malicious content

- Known malicious content
 - Known malicious domains (see e.g. PhishTank)
 - Known malware in attachments
- Potentially malicious content
 - Look-alike domains
 - Dangerous file formats in attachments (e.g., .exe)
 - Other suspicious indicators, e.g. certain keywords
- Alternative: only allow content from “allow-list”, e.g. only internal websites
 - can be too restrictive
- Alternative: include a warning in a suspicious email instead of blocking it entirely
 - manual verification needed



Phishing

Automatic verification issues

- Possible mistakes
 - False positives - legitimate emails are blocked
 - False negatives - phishing emails reach the user
- Technical know-how required for certain methods, e.g. signing and verifying signatures
- Threat intelligence can be lacking or outdated (e.g. in identifying malicious domains)
- Manual inspection sometimes needed

Phishing

Manual detection indicators

- Look and feel, e.g. spelling mistakes
 - Can be an indicator if the email is poorly made phishing email - might be enough to repel most of the attacks
 - However, professionally-looking phishing emails can be created
- Content of the email, e.g. suspicious requests, unusual wording, “Nigerian prince” frauds...
 - Can be an indicator in some cases (e.g. banks never asking for customers’ credit card data)
 - However, hard to detect with personalised emails
- Lack of security features (domain verification/lack of signature)
 - Can be an indicator if such features are expected
 - However, false positives possible
 - False negatives not excluded (e.g. if DMARC set up incorrectly)
- URL/attachment check: most reliable indicator, but requires knowledge on behalf of the users

Phishing

Phishing detection methods: Summary

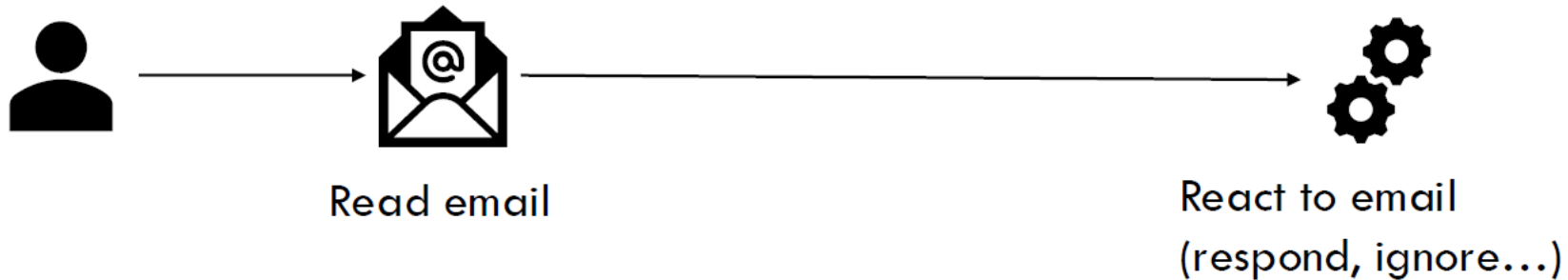
- Block phishing websites? - not always reliable to detect or fast enough to act
- Register all alike domains - requires resources; what if the attacker comes up with new tactics?
- Protect against sender spoofing (e.g. DMARC) - might work, but what if the recipient doesn't know the valid sender address?
- Use digital signatures - might be too complicated for the users to apply
- Rely on users to detect phishing links - unavoidable, but **can be challenging**

Phishing

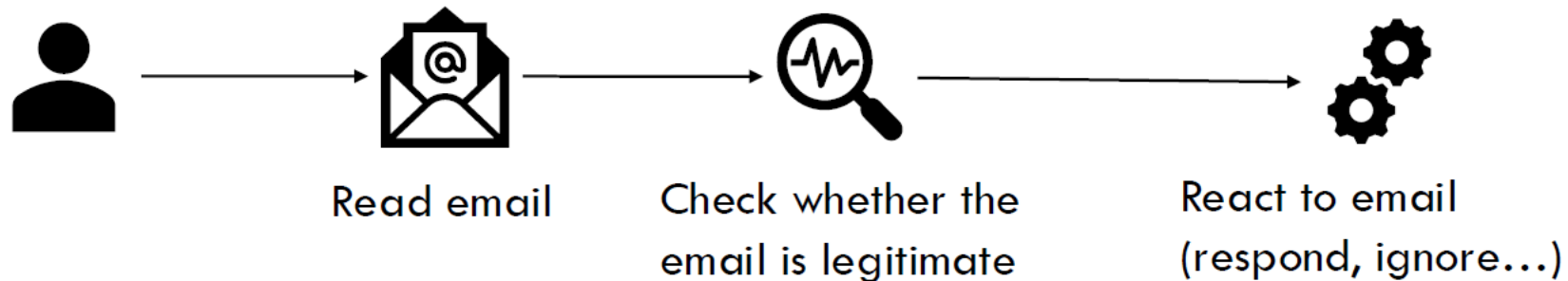
Why users find it hard to detect phishing

Task: Processing emails

- What the user wants to do



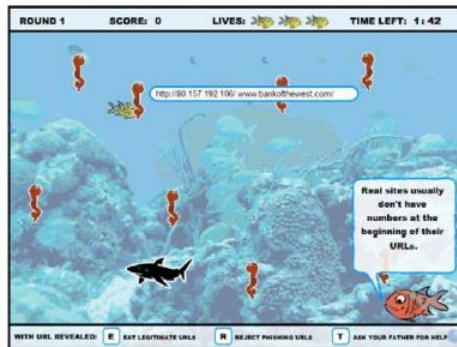
- What the user needs to do



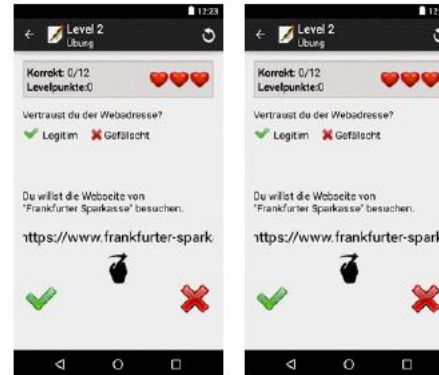
Phishing

Anti-phishing information materials

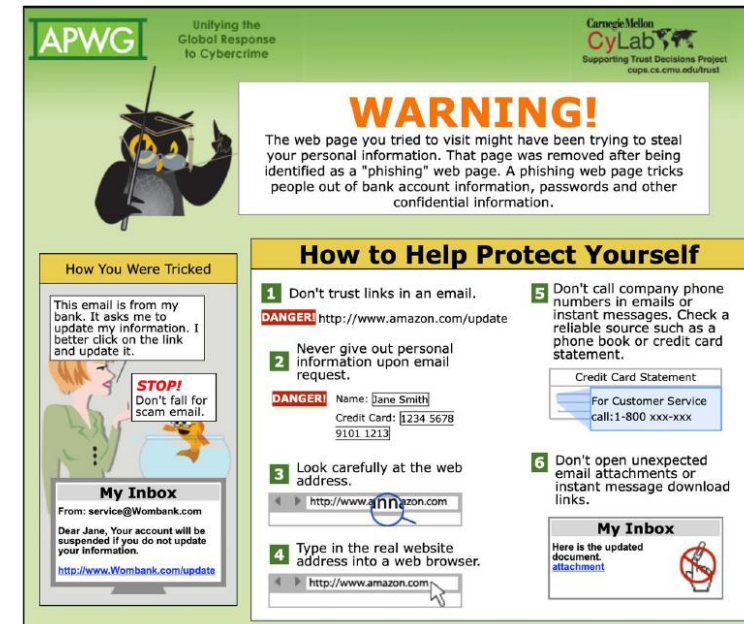
- Variety of media materials: E-learning modules videos, websites, paper materials, etc
- Gamification: Active learning, motivation,...
- Anti-phishing games such as NoPhish
- Embedded learning



Anti-phishing phil



NoPhish

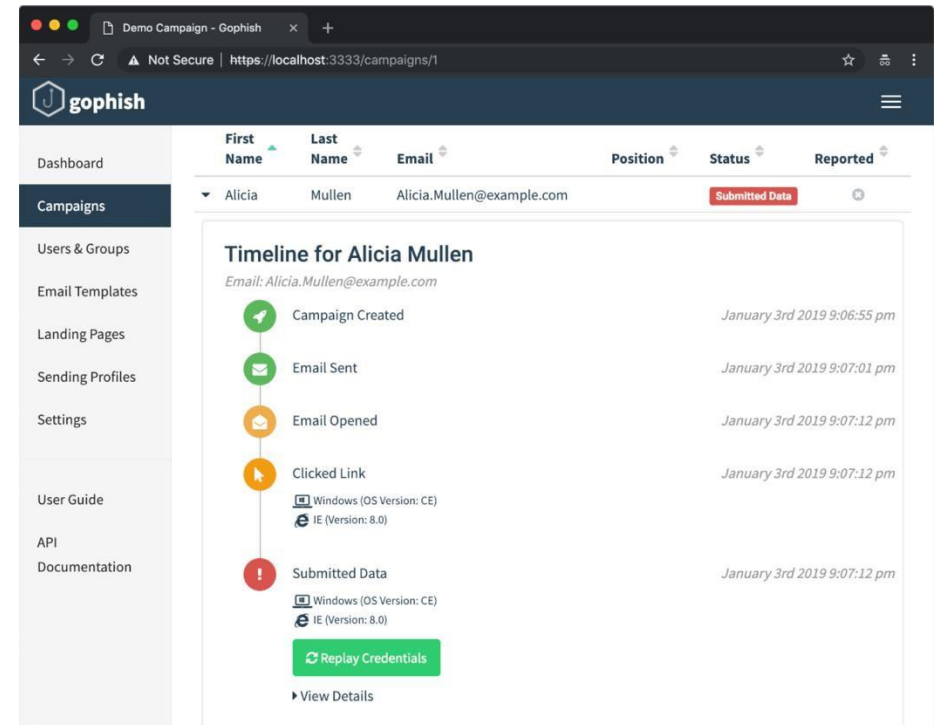


<https://phish-education.apwg.org/>

Phishing

Simulated phishing campaigns

- Goals
 - Evaluation: how many people click on the link/enter their credentials?
 - How vulnerable the organisation is to phishing attacks?
 - How effective the conducted security awareness measures are?
 - Teaching, e.g. combined with additional awareness materials
- Collected data
 - Rate of clicks or data entries only
 - Names of people clicking or providing data (e.g. entering passwords) on the website
 - Specific data provided on the website



GoPhish platform

Phishing

Issues with security education

- One-time measures are not enough
 - Habits take time to change
 - New people come to the organisations
 - Threats change, attackers become more clever etc.
- Putting responsibility solely on the user
 - Are there unreasonable demands on the users?
 - Do the users know how to report a phishing link?
 - Are there consequences for the user of reporting clicking on a phishing link?
- Lack of actionable advice
 - Instructions unclear (“don’t click on suspicious emails”)
 - Instructions unrealistic (“don’t visit websites you don’t know”)



<https://takefive-stopfraud.org.uk>

Class Demo

Phishing Simulation

Reference

→ GAMESS: <https://gamess.dk>

→ Social Engineering: The Science of Human Hacking by Christopher Hadnagy, 2nd Edition.

Thank You!